

Cybersecurity e protezione dei dati

Università degli Studi di Verona
Imbriani Paolo, VR553697
paolo.imbriani@studenti.univr.it
Professor Federica Paci

Anno Accademico 2026/2027

Indice

1 Cybersecurity 3
1.1 Cyber criminali 4
1.1.1 Lockbit 5
1.1.2 ALPHV / Black Cat 5
1.1.3 Access Brokers 5
1.1.4 Nation States oppure APTs 5
1.1.5 APT10 e Operation Cloud Hopper 5
1.1.6 Sandworm 5
1.1.7 Hacktivist 6
1.1.8 NoName057 (16) 6
1.1.9 Insiders 6
1.1.10 Edward Snowden 6
1.1.11 Intesa Sanpaolo 6
1.2 Scenari di attacco 7
1.3 Cyber Kill Chain 7
1.3.1 Fase di Ricognizione 7
1.3.2 Fase di Weaponization 8
1.3.3 Fase di Delivery 8
1.3.4 Fase di Exploitation 8
1.3.5 Fase di Installation 8
1.3.6 Command and Control 9
1.3.7 Azioni sugli obiettivi 9
1.3.8 TrickBot: 9
1.4 MITRE PRE-ATT&CK e ATT&CK 10
1.5 Attacchi AI 10
1.5.1 Targeted Poisoning 10
1.5.2 Backdoor Poisoning 10
1.5.3 Mitigating Poisoning Attacks 10
1.6 Generative AI 11
1.6.1 Attack Surface 11
1.6.2 Attack 11

1 Cybersecurity

La **Cybersecurity** cerca di garantire e mantenere le proprietà di sicurezza dell'organizzazione e gli asset degli utenti contro i rischi di sicurezza nel *cyberspace*.

La sicurezza è multidimensionale; proprietà diverse proteggono aspetti diversi di un asset:

- **Confidenzialità**: protezione delle informazioni da accessi non autorizzati.
- **Integrità**: protezione delle informazioni da modifiche non autorizzate.
- **Disponibilità**: protezione delle informazioni da interruzioni non autorizzate.
- **Autenticità**: che un entità o messaggio è genuino e verificato.
- **Safety**: persone e sistemi sono protetti da effetti negativi.
- **Responsabilità**: Le azioni devono essere tracciate per responsabilizzare le entità.

I concetti che ricorrono in cybersecurity sono:

- **Persone**: utenti, amministratori e partner
- **Tecnologia**: dispositivi, reti e applicazioni
- **Informazioni**: dati, documenti e credenziali
- **Infrastruttura**: Cloud, strutture e hardware
- **Vulnerabilità**: un bug, un imperfezione, una debolezza o esposizione di un applicazione, sistema, dispositivi o servizi che potrebbero portare al fallimento della confidenzialità, integrità o disponibilità di un asset.
- **Minaccia cyber**: è un evento che può risultare in un impatto negativo per l'azienda. Può essere un utente che inserisce una chiavetta infetta all'interno dei computer aziendali, etc.
- **Attacco**: un attacco è la realizzazione di una specifica minaccia che impatta l'integrità, confidenzialità o disponibilità di un asset.
- **Attore dell'attacco**: Una persona o un gruppo che cercano di sfruttare le vulnerabilità di un sistema per ottenere un impatto negativo.
- **Rischio**: Il livello di impatto sulle operazioni, asset o individui
- **Controllo di sicurezza**: Misure di sicurezza operazionali o tecniche per proteggere la confidenzialità, integrità o disponibilità di un asset.

1.1 Cyber criminali

L'interesse di questi criminali è un profitto illegale. Infatti sono molto comuni i Ransomware, che sono software che criptano i dati di un utente e chiedono un riscatto per decriptarli.

Gli attacchi tipici sono:

- **Phishing**: invio di email fraudolente per ottenere informazioni sensibili.
- **Sfruttamento delle vulnerabilità**: sfruttamento di bug o debolezze in software o sistemi per ottenere accesso non autorizzato.
- **Ransomware-as-a-service**: un modello di business in cui gli sviluppatori di ransomware forniscono il malware e l'infrastruttura per gli affiliati che vogliono condurre attacchi ransomware.
- **DDoS**: un attacco che mira a rendere un servizio indisponibile sovraccaricando il server con richieste.
- **Supply chain attack**: attacco a una catena di fornitori per compromettere un obiettivo finale.

1.1.1 Lockbit

Un ecosistema di ransomware costruito attorno al modello Ransomware-as-a-Service (RaaS). Un operazione di cybercrime che sviluppa e mantiene infrastruttura ransomware e recluta affiliati per compromettere vittime e distribuire il ransomware.

Gli operatori principali danno il malware, leak site e servizi di supporto. Gli affiliati conducono e condividono procedure di riscatto con gli operatori.

1.1.2 ALPHV / Black Cat

Questo gruppo è stato il primo ad introdurre il sistema di doppia estorsione. Non solo cifravano i dati, ma copiavano i dati in chiaro che se non avesse pagato la vittima, sarebbero stati pubblicati online.

1.1.3 Access Brokers

Gli access broker sono criminali che vendono l'accesso a reti compromesse, utilizzando malware chiamati information stealer. Sono capaci di accedere a tutte le location sulla macchina dove potrebbero esserci memorizzate le credenziali degli utenti.

Il tipo di credenziali che vengono rubate solitamente sono:

- Login e password
- Cookie di sessione e otken
- OTP (One Time Password)
- Kerberos e Kerberos tickets
- Chiavi API

1.1.4 Nation States oppure APTs

Ingaggiati dal governo, attaccano gli altri stati, facendo spionaggio, sabotaggio, sorveglianza o fake news.

Queste organizzazioni hanno l'obiettivo di creare nuovi strumenti d'attacco. Malware che spesso sono molto sofisticati e ad hoc per la struttura che devono colpire.

1.1.5 APT10 e Operation Cloud Hopper

Il gruppo APT10 (gruppo cinese) è noto per l'operazione Cloud Hopper. L'APT10 ha sfruttato un entità chiamata «Managed Service Providers» (MSP) per ottenere accesso a reti di grandi aziende. Gli MSP sono fornitori di servizi IT che gestiscono le infrastrutture tecnologiche di altre aziende. Hanno accesso privilegiato alle reti dei loro clienti, il che li rende un obiettivo attraente per gli attori delle minacce. Hanno ottenuto accesso ad uno degli MSP e ne hanno abusato il loro accesso fidato. Hanno raggiunto molteplici clienti e rubato i dati del loro target.

1.1.6 Sandworm

Sandworm è affiliato con il governo russo e sono stati condannati dall'FBI poiché responsabili di diversi attacchi in Ucraina. Hanno compromesso la rete elettrica nel 2005 e nel 2005. Sono stati anche colpevoli per aver compromesso le olimpiadi a Seoul.

1.1.7 Hacktivist

Sono attivisti che utilizzano le tecniche di hacking per promuovere una causa politica o sociale.

Motivazione:
- Visioni politiche
- Credenze religiosi o culturali
- National Pride
- Ideologie terroristiche

Attacchi tipici:
- DDOS
- Web defacement
- Data breaches or leaks
- Data wipers
- Distribuizione della propaganda

1.1.8 NoName057 (16)

Questo gruppo filorusso di hacktivist che ci concentrano sull'infangare e compromettere servizi pubblici piuttosto che rubare dati.

Avevano attaccato anche all'Italia poiché avevamo supportato l'Ucraina.

1.1.9 Insiders

Sono dipendenti di un azienda o comunque persone che hanno un rapporto con l'azienda e quindi hanno accesso ai dati e all'infrastruttura dell'azienda.

- L'agente negligente, cioè quello che non rispetta le regole di sicurezza e quindi mette a rischio l'azienda.
- Quella più pericolosa come attore sono quelli criminali, ovvero persone che hanno un interesse economico a rubare dati o danneggiare l'azienda.
- Gli attaccanti ottengono l'accesso ingannando gli altri impiegati, per esempio attraverso phishing o social engineering.

Il ruolo più comune e che causa più danni all'azienda degli insiders è quello di agente negligente.

1.1.10 Edward Snowden

Edward Snowden è un ex dipendente della CIA e della NSA che ha rivelato informazioni riservate sui programmi di sorveglianza di massa del governo degli Stati Uniti. Ha rivelato che la NSA aveva accesso a dati di cittadini americani e stranieri, inclusi dati di comunicazioni telefoniche e internet. Le sue rivelazioni hanno sollevato un dibattito globale sulla privacy, la sicurezza e l'etica della sorveglianza governativa.

1.1.11 Intesa Sanpaolo

Nel 2024, Intesa Sanpaolo ha subito un attacco informatico che ha compromesso i dati di circa 1,3 milioni di clienti. L'attacco è stato attribuito a un gruppo di cybercriminali che hanno sfruttato vulnerabilità nei sistemi della banca per ottenere accesso non autorizzato ai dati dei

clienti. L'incidente ha esposto informazioni personali e bancarie, creando un alto rischio nel diritto degli utenti, privacy e reputazione.

1.2 Scenari di attacco

Si è riscontrato, dagli ultimi report di cybersecurity, che gli attacchi sstanno aumentando e il profilo di impatto sempre più severo.

Se guardiamo i dati rispetto al 2021, c'è stato un aumento del 157%. Le cause potrebbero essere:

- L'introduzione dell'ANIS2, dove tra gli obblighi c'è quello di notificare le violazioni di dati personali entro 72 ore.
- Gli attaccanti utilizzano la GenAI per sviluppare attacchi sempre più complessi e sofisticati. Utilizzando GPT o Claude possono fare attacchi di phishing più realistici e personalizzare l'email in base all'obiettivo.

Gli attori più attivi sono cybercriminali (responsabili da soli dell'80% degli attacchi) seguiti subito dopo dagli hacktivist.

I settori più colpiti sono:

1. Target multipli
2. Government / Military / Defense
3. Healthcare
4. Manufacturing
5. ICT
6. Financial / Insurance
7. Professional / Scientific / Technical
8. Education
9. Wholesale / Retail
10. Transportation / Storage

1.3 Cyber Kill Chain

Una cyber kill chain descrive le fasi di un attacco informatico, dalla pianificazione iniziale fino al raggiungimento dell'obiettivo finale. Comprendere la kill chain aiuta le organizzazioni a identificare e mitigare le minacce in ogni fase del processo di attacco.

1.3.1 Fase di Ricognizione

La fase di ricognizione è la prima fase dalla kill chain dove l'attaccante raccoglie informazioni sull'obiettivo.

Ci sono strumenti attivi o passi:

- Passivi:
  - whois
  - shodan
  - Google and social media
  - Maltego
- Attivi:
  - nmap

- port scanning
- vulnerability scanning

1.3.2 Fase di Weaponization

L'obiettivo è quello di trovare o creare un attacco che sfrutta una debolezza. Strumenti comuni e frameworks:

- Metasploit
- Exploit DB
- Veil Framework
- Social Engineering Toolkit
- Cain and Abel
- Aircrack
- SQLMap

1.3.3 Fase di Delivery

Bisogna scegliere il canale in cui effettuare l'attacco. Alcuni esempi sono:

- Email
- Website
- User input
- USB

1.3.4 Fase di Exploitation

- SQL injection: sfruttare vulnerabilità nei database per eseguire comandi non autorizzati.
- Buffer overflow: inviare dati in eccesso a un programma per sovrascrivere la memoria e ottenere l'esecuzione di codice arbitrario.
- Malware: installare software dannoso per compromettere il sistema.
- JavaScript hijacking: sfruttare vulnerabilità nei browser per eseguire codice malevolo.
- User exploitation: ingannare gli utenti per ottenere accesso non autorizzato, ad esempio tramite phishing o social engineering.

1.3.5 Fase di Installation

L'obiettivo di questa fase è quello di mantenere la presenza dell'attaccante nel sistema compromesso. Alcuni metodi comuni di installazione di malware includono:

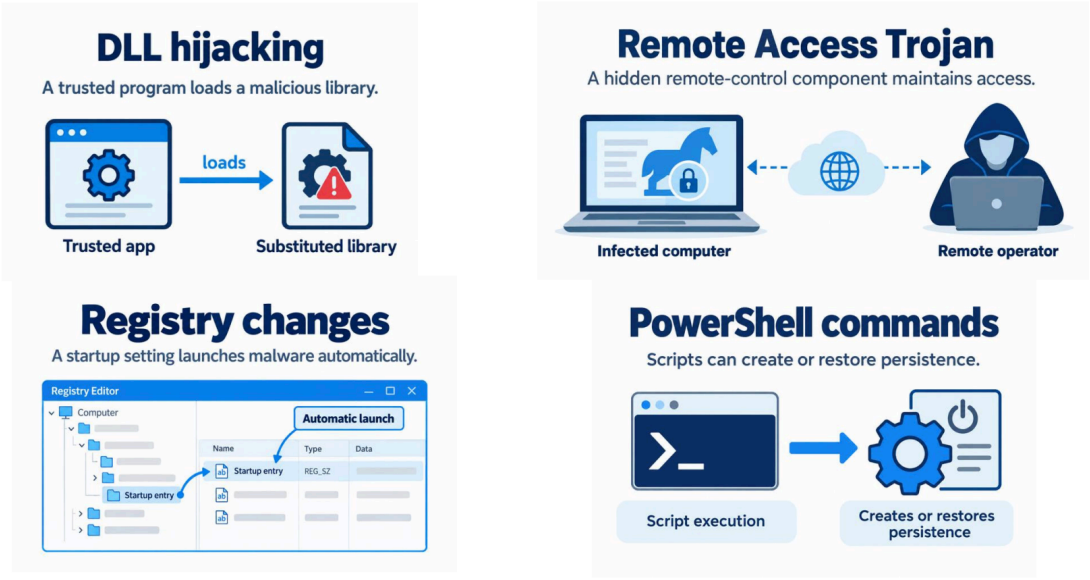


Figura 1: Metodi di installazione di malware

1.3.6 Command and Control

L'obiettivo è quello di stabilire il canale con l'attaccante per manipolare da remoto la vittima. Alcuni esempi:

- Canale di comunicazione a due vie per l'infrastruttura C2
- Alcuni canali comuni di C2 usano web, DNS, email
- L'infrastruttura C2 può essere ospitata dall'avversario oppure dalla macchina compromessa di una vittima

1.3.7 Azioni sugli obiettivi

In questa fase l'attaccante cerca di ottenere i suoi obiettivi attraverso l'ambiente compromesso:

- Raccolta delle credenziali degli utenti
- Escalation dei privilegi
- Ricognizione interna
- Movimento laterale
- Raccolta ed esfiltrazione dei dati
- Distruzione dei sistemi
- Sovrascrivere o corrompere i dati
- Modificare i dati in modo nascosto

1.3.8 TrickBot:

TrickBot è un Trojan che si è distribuito attraverso spearphishing con email mirate, allegati dannosi o link che eseguono malware.

Un esempio era quello dove usava un email che affermava di contenere prove di una violazione del traffico. Il link portava a un sito web compromesso. L'utente scaricava un file JavaScript che contattava il server C2 e scaricava TrickBot sul sistema.

Gli operatori usavano trickbot per:

- Rilasciare altri malware, includendo Ryuk e conti Ramsomware
- Serviva a un downloader Emotet
- Muoversi ateralmente attraverso SMB
- Rubare dati e performare cryptomining
- Enumarare gli host nella rete e i loro firmware

1.4 MITRE PRE-ATT&CK e ATT&CK

I framework MITRE (organizzazione no-profit americana) ATT&CK è una base di conoscenza globale di tattiche e tecniche di attacco informatico basata su osservazioni del mondo reale. Fornisce un linguaggio comune per descrivere le azioni degli avversari e aiuta le organizzazioni a comprendere, rilevare e rispondere alle minacce.

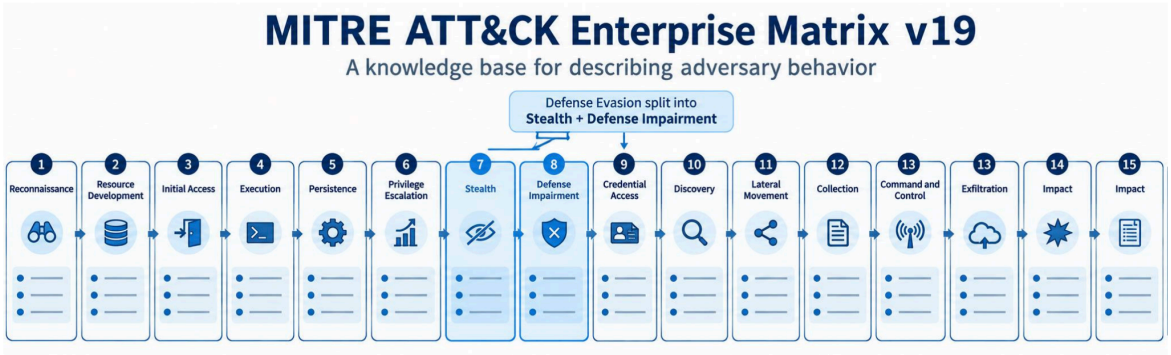


Figura 2: MITRE ATT&CK e PRE-ATT&CK

1.5 Attacchi AI

L'IA predittiva si riferisce a sistemi di intelligenza artificiale che utilizzano analizi statiche e algoritmi d machine learning per fare predizioni. L'obiettivo di un attacco a sistemi AI mirano a compromettere la sicurezza, l'integrità o la disponibilità di un sistema AI. Alcuni esempi di attacchi includono:

1.5.1 Targeted Poisoning

Solo alcune categorie di dati vengono compromesse. Per alcune dati il modello genererà una previsione corretta, mentre per quei dati compromessi il modello genererà una previsione errata. Si usa il label flipping: inserirà nel modello di training dei dati favorevoli per l'attaccante, inserendo dati con label sbagliati.

1.5.2 Backdoor Poisoning

Un attaccante può inserire un trigger nel modello di training, che quando viene attivato, il modello genererà una previsione errata.

1.5.3 Mitigating Poisoning Attacks

Alcune strategie per mitigare gli attacchi di avvelenamento includono:

- Data sanitization: rimuovere o filtrare i dati sospetti prima di addestrare il modello.

- Robust training: utilizzare tecniche di addestramento robuste che riducono l'impatto dei dati avvelenati.
- Monitor Model performance: monitorare le prestazioni del modello per rilevare eventuali anomalie o cali di precisione che potrebbero indicare un attacco di avvelenamento.

1.6 Generative AI

1.6.1 Attack Surface

1.6.2 Attack